



A novel risk-based access control engine in zero trust architecture for IoT network

Yi-Wei Ma¹ · Po-Hung Chiu¹

Accepted: 28 March 2025 / Published online: 5 May 2025
© The Author(s) 2025

Abstract

The Internet of Things (IoT) and Wireless Sensor Network (WSN) market has grown recently. Therefore, security issues on IoT Networks are considerably important. This study proposes the zero trust-enabled trust evaluation mechanism that continuously evaluates the trust of neighbor nodes to prevent attackers from endangering the availability and reliability of the overall IoT networks. In zero trust, each node's behavior should be considered to avoid damage to the overall network. This study uses various indicators to evaluate the trust of each interaction behavior, including capability, feature, activity, and data contents. This study evaluates the behaviors through the ability of the interaction node and the expected behavior. The experiment result shows that the proposed method can detect and mitigate the four types of attacks in Routing Protocol for Low-Power and Lossy Network (RPL), and the proposed method has less misjudgment.

Keywords Zero trust · Zero trust architecture · Defense technique · Trust evaluation · Risk assessment · Internet of things

1 Introduction

1.1 Motivation

The Internet of Things (IoT) market has increased recently [1]. The security of IoT applications is becoming increasingly important as it ensures the reliability of data and the system's availability after the attacks happen. In addition, the Wireless Sensor Network (WSN) is becoming increasingly popular [2]. Therefore, the security issue of WSNs is also significant. However, WSN usually involves collaboration among nodes, so the trust evaluation of other nodes is essential. In the IoT Network, the attacker may affect the availability of the IoT Network or tamper with the sensor data, which is called a False Data Injection (FDI) attack [3, 4]. Therefore, this study hopes to protect each node with zero trust. This study performed continuous trust evaluation and risk assessment on neighbor nodes through the proposed trust metrics to find malicious nodes and then make dynamic mitigation policy decisions based on the calculated trust values to

reduce the influence of attackers on the overall IoT Network, as shown in Fig. 1.

1.2 Contribution

This study proposed the trust evaluation for IoT networks. The novelty of proposed framework differs from prior risk-based access control mechanisms and the contributions include as follows.

1. This study designs the trust evaluation, risk assessment, and dynamic policy module for IoT networks.
2. This study establishes the capabilities table to describe the benefits of nodes.
3. This study establishes the features table to describe the observation behavior of nodes.
4. This study establishes the activities table to describe the expected behavior of nodes.

2 Related work

2.1 Traditional intrusion detection system (IDS)-based method

IDS can detect attacks located anywhere. However, proposing a lightweight IDS for detecting attacks on IoT networks

✉ Yi-Wei Ma
ywma@mail.ntust.edu.tw

¹ Department of Electrical Engineering, National Taiwan University of Science and Technology, Taipei, Taiwan

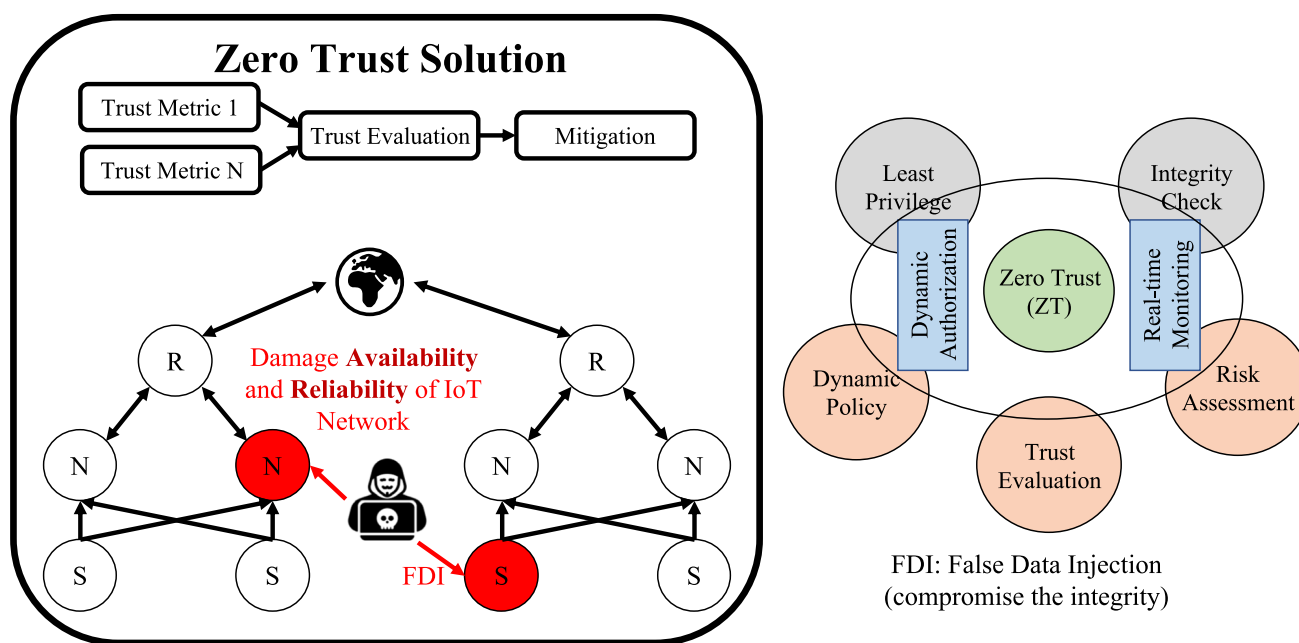


Fig. 1 The Concept of Zero Trust Mechanism

is still challenging. Traditional IDS is divided into signature-based and anomaly-based IDS. The Signature-based IDS (SIDS) is typically good at identifying known threats. It usually computes Indicators of Compromise (IOC) to determine the attacks on the system. IOC contains information about the attacks, such as attacker IP, abnormal traffic from foreign countries, and frequency of messages. However, the increasing rate of zero-day attacks [5] reduces the effectiveness of SIDS.

The Anomaly-based IDS (AIDS) is based on heuristics or rules. Its objective is to detect all attacks, whether they are known attacks. AIDS is divided into two types: behavioral-based IDS and specification-based IDS. Behavioral-based IDS [6] will learn the behavior of a monitored system and judge the anomaly behavior according to the learning phase. The Specification-based IDS [7, 8] is a knowledge-based system consisting of many behavior rules defined by the experts. These rules are derived from the system specification and security requirements. However, AIDS will also raise alerts to non-malicious behaviors. Thus, additional time and resources are required to investigate all the alerts to potential threats for system maintainers.

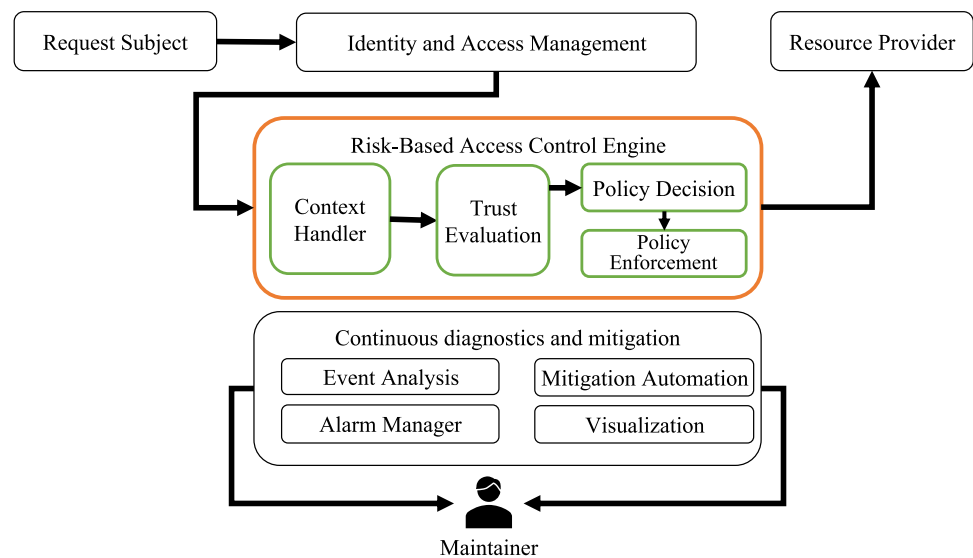
The AI-enabled IDS [9–11] aims to use deep learning to learn the behavior of attacks and detect them in the network environment. AI-enabled IDS using an actual positive rate (TPR) and a false positive rate (FPR) to evaluate. However, it depends on the dataset to generate an AI model. It usually has a high detection rate but requires heavy computing resources.

Applying cryptography to communication can ensure confidentiality and integrity. Digital signatures and Physically

Unclonable Functions (PUFs) provide authentication features for communication to ensure the authenticity of identity. Digital signatures [12] are based on mathematical calculations that are considered very hard to solve so that they can prevent forged identity. Digital signatures are based on public-key cryptography. Public-key cryptography mainly contains RSA and ECDSA. PUFs [13] depend on hardware and have three types: analog electronics, memory-based, and delay-based. The analog electronic PUFs are based on the physical differences in electrical properties. The memory-based PUFs are based on the randomness of powered-on voltage in memory units. The delay-based PUFs are based on the variations of propagation delay in digital signals. However, cryptography can only ensure the authenticity of identity and cannot prevent other attacks independent of identity.

In sensor networks, trust refers to the sensor node's reliability, integrity, and behavior. From the information security perspective, trust is a relationship between participating entities in network activities. The concept of risk evaluation is similar to trust evaluation. They aim to evaluate whether the decision is correct.

The Trust-Based method [14] is usually based on the trust evaluation function and threshold design. The trust evaluation function comprises several metrics and is a weighted score calculation. The request subject is seen as trust because the weighted score is more significant than the trust threshold. Furthermore, the historical trust score represents the user behavior. Thus, this should be considered in the trust evaluation.

Fig. 2 Zero Trust Architecture

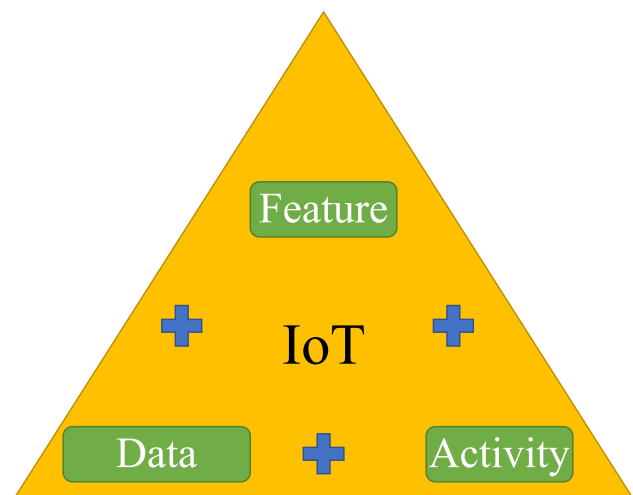
In IoT networks, several studies [15–21] focus on the trust evaluation of nodes. They aim to ensure the reliability of the routing protocol and prevent malicious nodes from damaging routing. They derive trust from the combination of direct trust (DT) and indirect trust (IDT). However, considering IDT may cause the whole system to be affected by infected nodes. In addition, most research focuses on a single type of attacker. At present, many researchers have proposed some papers related to this study, all of which illustrate the importance and necessity of the existence of this phenomenon [22–31].

3 Proposed trust evaluation

This study proposes the Risk-Based Access Control Engine (RBACE) on zero trust architecture for IoT networks, as shown in Fig. 2. The proposed RBACE aims to calculate the present request's risk and trust values to ensure availability and reliability. The Identity and Access Management (IAM) module aims to verify the identity or extract the information about the requester and defense identity-based attacks. Furthermore, it will use the calculated score to determine the policy for this requester. The Continuous Diagnostics and Mitigation (CDM) module aims to protect the system and ensure system resilience. Above all, it will also provide information for behavior analysis to help the proposed system find potential threats.

3.1 Trust definition

This study defines trust as how the entity believes in the system. Furthermore, trust consists of the capability and risk of an entity from the system perspective, as shown in Eq. (1). The performance capability represents how much the entity

**Fig. 3** The basis of trust evaluation

benefits the system. The risk means the possibility of an entity causing harm to a system. The performance capability evaluates the specific node's ability to forward data in WSN. The risk is used to assess the possibility that a particular node is malicious. The $w1$ and $w2$ means the weight distribution.

$$Trust = w1 * PerformanceCapability - w2 * Risk \quad (1)$$

The trust evaluation process is based on features, activities, and data content, as shown in Fig. 3. Features collect action information generated by a specific node. Activities are used to observe the behavior of a particular node. Data are used to collect information on the system. The nodes that need to be evaluated will determined by activities. Features and data are used in risk assessment.

Most IoT applications aim to collect and use data to analyze user behavior or the status of assets. Thus, the security of IoT networks is a critical issue for organizations. Therefore, this study focuses on trust evaluation.

3.2 Context handler component

The context handler component collects relevant contextual information crucial for evaluating trust. Calculating trust value requires extracting capabilities, features, and activities, as shown in Fig. 4.

Table 1 shows the performance capabilities evaluation. Since the IoT Network involves cooperation among nodes, the assessment of neighbor nodes' ability is essential to ensure the reliability of the IoT Network. The capabilities one (C1) Energy level_j mean a node represents the remaining energy of the node j. Because the nodes in an IoT Network usually have a power-saving mechanism, they will enter the Low Power Mode (LPM) and increase the transmission delay as the energy level is low. In addition, it may also cause the packet to be forwarded or the response from the server not to be sent correctly because LPM will increase the sleep period. Therefore, a high energy level means that the link of a specific node is highly reliable. On the contrary, a low energy level represents lower reliability. The Received Signal Strength Indication $RSSI_{ij}$ (C2) indicates the signal strength of the specific node j measured by node i. The higher Received Signal Strength Indication (RSSI) value usually represents the high reliability of the link. Since RSSI is the received power strength, it is usually represented by a negative number. Expected transmission count ETX_{ij} (C3) estimates the transmissions required to successfully deliver a packet between two nodes, i, j. Lower Expected Transmission Count (ETX) represents the high reliability of the link. The most ideal situation is $ETX = 1$. That is, there is no packet loss.

Table 2 shows the feature observation. The proposed system measures behavior by observing the information generated by actions. The following are the observed behavioral features. The Packet Sending Ratio (F1) $PSR_{i,j}(T_i)$ represents the ratio of the response received packets from node i through node j in the period T_i . However, F1 cannot be used to identify malicious nodes individually. Therefore, the grandparent node k of node i will measure the Packet Forwarding Ratio (F2) $PFRR_{k,j}(T_i)$, of its parent node j to help identify malicious nodes. However, grandparent nodes may also be malicious nodes. Therefore, each node will judge whether the received F2 value is reasonable according to F1.

The Destination Advertisement Object – Acknowledgement (DAO-ACK) Response Ratio (F3) $R_{ij}^{DAO-ACK}(T_i)$ represents the ratio of Destination Advertisement Object (DAO) sent to node j from node i in the period T_i . When a malicious node j conducts a DODAG Information Object

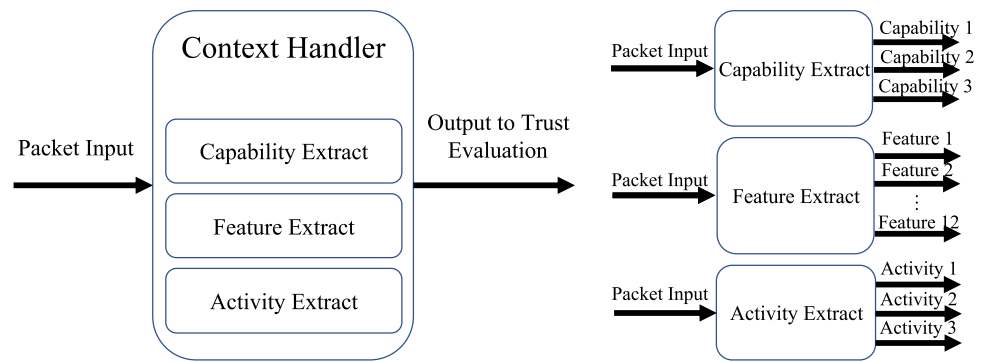
(DIO) Flooding Attack, it may drop DAO from node i due to its processing ability. Consequently, malicious node j would not respond to DAO-ACK about the received DAO from node i. The Number of DIO Packets Receive (F4) $N_{ij}^{DIO}(T_i)$ represents the node i received DIO packets from node j in the period T_i . Observing whether F4 exceeds the normal behavior threshold identifies malicious nodes conducting DIO Flooding attacks.

The Number of DAO Packets Receive (F5) $N_{ij}^{DAO}(T_i)$ represents the number of DAO packets received by node i from node j in the period T_i . By observing F5 to identify the DAO flooding attacks. The Number of DODAG Information Solicitation (DIS) Packets Receive (F6) $N_{ij}^{DIS}(T_i)$ represents the number of DIS packets received by node i from node j in the period T_i . By observing F6 to identify the DIS flooding attacks.

The Number of DIO Sent (F7) $NS_{ij}^{DIO}(T_i)$ represents the number of DIOs sent to node j by node i in the period T_i . The value of F7 will determine how much DAO and DIS would be sent by neighbor nodes. Observing F7 to identify whether the neighbor nodes are conducting DAO or DIS flooding attacks. The Rank of Node (F8) $Rank_{i,j}$ represents the rank of node j received by node i. Every node will observe the rank value of their neighbor nodes by receiving DIO from them. The rank value is positively related to the hop count and distance to the root node of a DAG. However, the malicious node will temper with the rank value to destroy the availability or reliability of the IoT network, which is called a rank attack. Thus, consider the F8 of neighbor nodes to derive the reasonable range of rank value.

The Rank Variation of Node (F9) $\Delta Rank_{i,j}(t = k)$ represents the rank variation of node j at time k. Since the rank value will not change drastically when the route is stable, F9 will be observed to identify rank attacks. The Correctness of Version Provide (F10) $P_{VN=NewVerofj}$ represents the correctness of the version provided by node j. Since malicious nodes will destroy the stability of the overall IoT Network by tampering with the version in DIO, called version attack, confirm every version number update.

The Observed Time Interval of the Version Update (F11) $t_{ij}^{Verupdate}$ represents the observed time interval of the version update from node j. To ensure the link's stability and reduce the nodes' power consumption, the value of F11 should not be too small. That is, F11 should be greater than the predefined threshold. In addition, check the version number only when F11 is greater than the threshold value in consideration of the algorithm's performance. The Estimated ETX Value of the Link (F12) $EstimatedETX_{ij}$ represents the estimated ETX value of the link between node i and node j. F12 is estimated by $RSSI_{ij}$ (C2). Theoretically, the larger the value of RSSI, the smaller the value of ETX and the more reliable the link. Assuming $RSSI \geq RSSI_{max}$, $ETX = 1$ can be obtained, and $RSSI < RSSI_{min}$ will cause all packets to be lost, that

Fig. 4 Context Handler component**Table 1** Performance capability evaluation

Properties	Capabilities		
	CI	C2	C3
	$Energy\ level_j$	$RSSI_{ij}$	ETX_{ij}
Description	- Energy level is used to indicate the power remaining of the node j - Higher energy level represents the link of node j has high reliability of link	- Received Signal Strength Indication is used to indicate the signal strength of the node j measured by node i - Higher RS SI usually represents high reliability of the link	- Expected transmission count is an estimation of the number of transmissions required to successfully deliver a packet between two nodes i, j - Lower ETX represents high reliability of link $ETX_{ij} \geq 1$
Numeric	$C_1 = \begin{cases} C_1^H, & \text{when } TH_{C1,H} \leq C_1 \leq 100\% \\ C_1^M, & \text{when } TH_{C1,L} \leq C_1 < TH_{C1,H} \\ C_1^L, & \text{when } 0 \leq C_1 < TH_{C1,L} \end{cases}$	$C_2 = \frac{C_2^H * (RSSI - RSSI_{min})}{(RSSI_{max} - RSSI_{min})}$	$C_3 = \frac{C_3^H}{ETX_{ij}}$

is, $ETX = \infty$. Comparing C3 with F12 can detect whether the specific node is selfish.

The activities that need to be observed in the IoT Network are shown in Table 3. Layer 2 Connection (A1) represents the connection between two nodes in Layer 2. Every node will determine whether to receive the packet from neighbor nodes, according to A1. Thus, A1 can be used to determine which node should be evaluated. Link Relationship (A2) represents the link between two nodes observed by node i . Every node can observe A2 by receiving DAO from its child node. The proposed system can use A2 to determine which nodes should forward the data packet from their child nodes. A2 can help identify which node is conducting a blackhole attack. Send Data (A3) represents the observed data-sending activity. That is, A3 can be used in conjunction with A2 to determine whether to evaluate whether a neighbor node is conducting a Blackhole Attack. The term a_j^1 represents whether the behavior of node j can be observed in the current node. The term a_{jk}^2 represents whether the node j will receive a data packet from node k and forward it. The term a_k^3 the node k is sending data packet. If the multiplication of a_{jk}^2 and a_k^3 is equal to 1,

it means that node j should forward the data packet. By substituting the number of packets sent by node k into A3, this work can get the expected number of forwarding packets of each node by using $A_1 \cap (A_2 \times A_3)$. Furthermore, this value is the denominator of F2, and the numerator of F2 is calculated by a counter. That is, the activities can help calculate F2.

The minimum sending interval of DIO (D1) $Min_{DIOinterval}$ represents the minimum sending interval of DIO. A normal node will check that the time interval from the last DIO transmission is greater than D1 before each. Therefore, it can be used to identify whether a malicious node is conducting a DIO Flooding Attack. The expected time interval of version update (D2) $T_{VNupdate}$ represents the expected update interval of the version number. That is, the value of D2 is the threshold of F11 to mitigate the Version Attack.

Table 2 IoT network feature observation

Properties	Features	
	F1	F3
	$PSR_{i,Route\ of\ j}(T_i)$	$R_{ij}^{DAO-ACK}(T_i)$
Formulation	$\frac{Number\ of\ response}{Number\ of\ send\ by\ i}$	$\frac{Number\ of\ received\ DAO-ack\ from\ j}{Number\ of\ DAO\ sent\ by\ i}$
Description	Packet Sending Ratio of a route of node j measured by node i in time period T_i	DAO-ACK Response Ratio of node j measured by node i in time period T_i
Properties	Features	
	F4	F5
	$N_{ij}^{DIO}(T_i)$	$N_{ij}^{DAO}(T_i)$
		F6
		$N_{ij}^{DIS}(T_i)$
		F7
		$N_{ij}^{DIO}(T_i)$
		F8
		$Rank_{i,j}$
Formulation	Counter	Counter
Description	Number of DIO packets receive by node i from node j in time period T_i	Number of DIO sent to node j by node i in time period T_i
		In DIO packet
		Rank of node j received by node i
Properties	Features	
	F9	F10
	$\Delta Rank_{i,j}(t = k)$	$P_{Ver} = NewVer\ of\ j$
		F11
		$Ver\ update\ t_{ij}$
		F12
		$Estimated\ ETX_{ij}$
Formulation	Derive from F8	Timer
		$\frac{\sum number\ of\ Ver = NewVer\ of\ j}{\sum number\ of\ Ver\ votes}$
Description	Rank variation of node j at time = k measured by node i	The time interval of version update from node j observed by node i
		$NewVer\ of\ j$ is the new provided by node j
		The correctness of version provided by node j
		$RSSI_{min} \leq RSSI_{ij}^{Bounded} \leq RSSI_{max}$
		The estimated ETX value of link between node i and j can be derive from $RSSI_{ij}$

Table 3 IoT activity for trust evaluation

Properties	Activities		
	A1	A2	A3
	Layer 2 Connection	Link Relationship	Send Data
Description	Before sending any packet to neighbor nodes, the connection in layer 2 should be established	Each node will have its parent node. Thus, we can observe which node should send or propagate data by using A2	Each node can observe which node is sending data by check the source of packet
Expression	$\begin{bmatrix} a_1^1 \\ a_2^1 \\ \vdots \\ a_n^1 \end{bmatrix}$	$\begin{bmatrix} a_{11}^2 & \cdots & a_{1n}^2 \\ \vdots & \ddots & \vdots \\ a_{n1}^2 & \cdots & a_{nn}^2 \end{bmatrix}$	$\begin{bmatrix} a_1^3 \\ a_2^3 \\ \vdots \\ a_n^3 \end{bmatrix}$

3.3 Trust evaluation component

Calculating the trust value requires considering capability and risk, as shown in Eq. (2). However, the calculation of trust value represents behavior analysis of the node. The behavior analysis of the node needs to consider both historical trust value ($\text{Trust}(t=n-1)$) and current trust value ($\text{Capability}(t =$

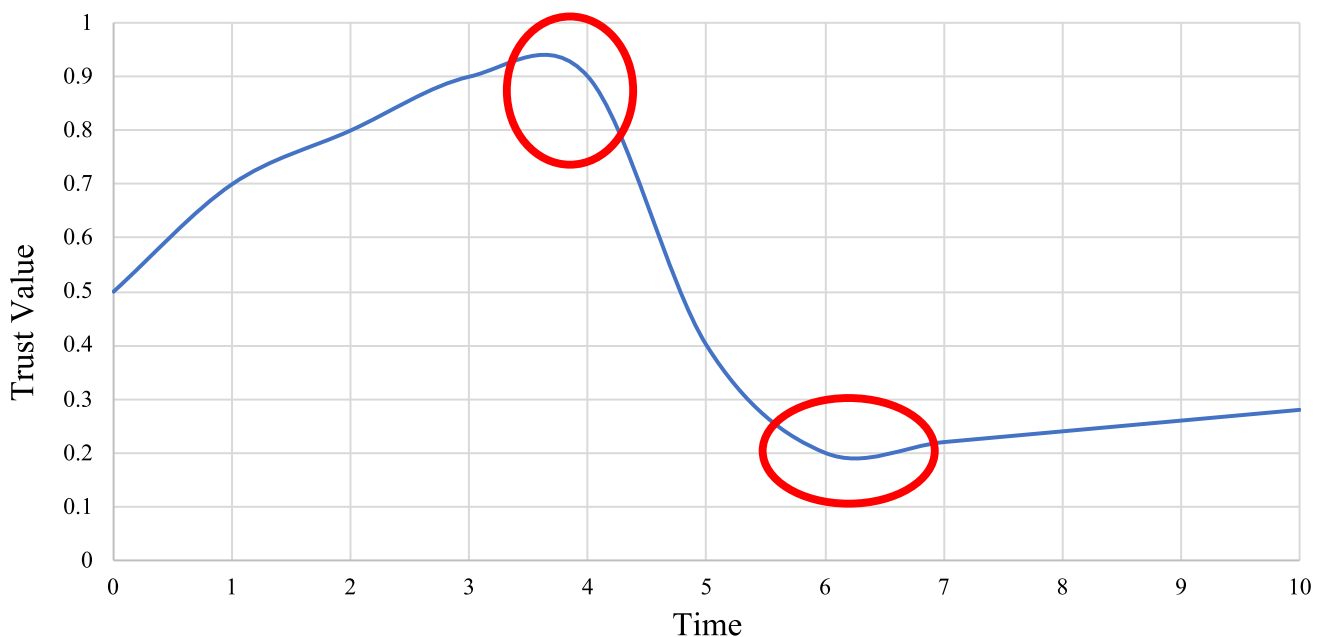
$n) - \text{Risk}(t = n)$). In Eq. (3), the final trust value is the weighted score of the current trust value and the previous final trust value, whereas the sum of weights equals 1, as shown in Eq. (4). Figure 5 shows the expected result of trust value over time, whereas the weights in different conditions are shown in Eq. (5). To lessen the impact of malicious nodes on the overall system, the punishment for malicious behavior will be heavier. TH_{trust} is the threshold of acceptable trust value. If the current trust value of the node is lower than TH_{trust} , it means that the behavior of the node may be malicious, whereas W_1 is set to 0.8. The final trust value is mainly derived from the current trust value. If the previous final trust value of the node is lower than TH_{trust} , it means that the behavior of the node in the past may be malicious whereas W_1 is set to 0.1. That is, the final trust value is mainly derived from the previous final trust value. If the current trust value of the node is high, it means that the behavior of the node is normal, whereas W_1 is set to 0.3. That is to avoid the final trust value depending only on current behavior.

$$\text{Trust}(t=0) = \text{Capability}(t=0) - \text{Risk}(t=0) \quad (2)$$

$$\text{Trust}(t=n) = W_0 \times \text{Trust}(t=n-1) + W_1 \times (\text{Capability}(t=n) - \text{Risk}(t=n)) \quad (3)$$

$$W_0 + W_1 = 1 \quad (4)$$

$$W_1 = \begin{cases} 0.8 & \text{if } (\text{Capability}(t=n) - \text{Risk}(t=n)) < TH_{trust} \\ 0.1 & \text{if } \text{Trust}(t=n-1) < TH_{trust} \\ 0.3 & \text{else} \end{cases} \quad (5)$$

**Fig. 5** The expected result of trust value over time

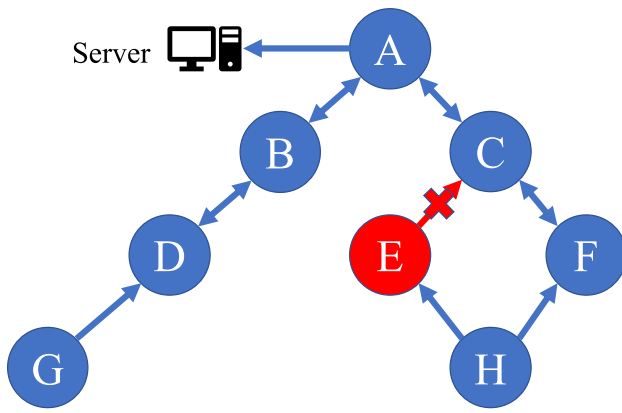


Fig. 6 Blackhole attack

3.3.1 Selfish

There are two possible reasons why a node is selfish:

1. The node does not process other packets temporarily because the energy level is low or to extend the battery life.
2. It may be an attacker intent on disrupting the availability of the network.

Both situations consider risks to ensure the transmission's reliability in the system.

When a system evaluates a neighbor node as selfish, it must assess whether or not the node's capabilities match its estimated capabilities. That is, $F12$ ($EstimatedETX_{ij}$) and $C3$ (ETX_{ij}) are used to calculate $Risk_{ij}^{selfish}$ as shown in Eq. (6).

$$Risk_{ij}^{selfish} = \frac{\max(0, C3 - F12)}{F12} \quad (6)$$

3.3.2 Blackhole attack

Figure 6 shows the blackhole attack in Routing Protocol for Low-Power and Lossy Network (RPL). The attacker will drop the data packet from their child routes. That is, it will prevent data packets from being sent to the server, so its behavior is to send packets selectively. As a result, an attacker's behavior would be inconsistent with its demonstrated capabilities. Each node can judge whether the parent and child nodes are conducting Blackhole Attacks to avoid damaging availability and reliability from attackers in the IoT Network.

When a node sends a data packet to the server, it will send it through the route of the parent node. Therefore, each node will calculate $F1$ ($PSR_{i, Routeofj}(T_i)$) for the parent node continuously, and judge whether it is reasonable. That is, the value of $F1$ needs to match the value of $C3$ (ETX_{ij}). Since the reciprocal of $C3$ is the successful transmission rate of control packets, the reciprocal of $C3$ will be close

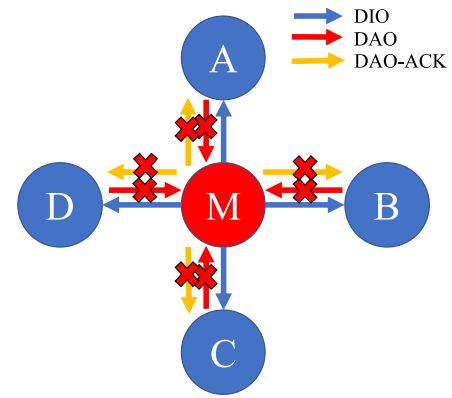


Fig. 7 DIO Flooding Attack

to $F1$ theoretically. That is, the multiplication of $F1$ and $C3$ is close to 1. When this value is less than 1, the specific node has selective forwarding behavior. Equation (7) means the probability that a parent node is conducting a blackhole attack. Furthermore, $Risk_{ij}^{Blackholeattack}$ will be calculated in consideration of $Risk_{ij}^{selfish}$ and $Risk_{ij}^{Blackholeattack}$ as shown in Eq. (8). This study presumes that when a node is selfish, it is more likely to be an attacker of BlackHole Attack.

$$P_{ij}^{BlackholeAttack} = \max(0, 1 - F1 \times C3) \quad (7)$$

$$Risk_{ij}^{BlackholeAttack} = \begin{cases} P_{Blackholeattack} & \text{if } Risk_{ij}^{selfish} < 0.5 \\ 2 * P_{Blackholeattack} & \text{if } Risk_{ij}^{selfish} \geq 0.5 \end{cases} \quad (8)$$

Each node also evaluates whether its child nodes are conducting black hole attacks to ensure the network has reliable routing. Each node observes the data packets from its grand-child nodes and calculates the value of $F2$ ($PSR_{i,j}(T_i)$). $F2$ needs to match the value of $C3$ (ETX_{ij}). That is, the multiplication of $F2$ and $C3$ is close to 1. When the value is less than 1, the child node has selective forwarding behavior. Therefore, Eq. (9) shows the probability that a child node is conducting a blackhole attack.

$$P_{ij}^{BlackholeAttack} = \max(0, 1 - F2 \times C3) \quad (9)$$

3.3.3 DoS attack

Denial of Service (DoS) attack means that a malicious node aims to damage the availability of the IoT network. That is, the malicious node will frequently send control packets to RPL. DoS Attacks in RPL are classified into three types:

3.3.3.1 DIO flooding attack In Fig. 7, assume that node M is a malicious node. It will rapidly send DIO control messages

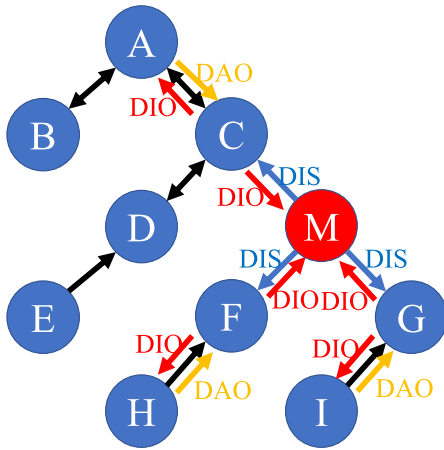


Fig. 8 DIS Flooding Attack (DIS will trigger multicast DIO and then trigger DAO)

and usually deny DAO. Thus, using the DAO-ACK packet ensures that the control packets are bidirectional. Where $TH_{ij}^{DAO-ACK}$ is threshold of DAO-ACK received ratio and $TH_{ij}^{DIOcount}(T_i)$ is threshold of number of DIO packets from node j in the period T_i . $TH_{ij}^{DAO-ACK}$ can be determined by the value of C3 (ETX_{ij}) shown as Eq. (10). $TH_{ij}^{DIOcount}(T_i)$ can be determined by the value of C3 (ETX_{ij}) and D1 ($Min_{DIOinterval}$) shown as Eq. (11). Equation (12) calculates the risk of each node conducting DIO Flooding.

$$TH_{ij}^{DAO-ACK} = \frac{1}{C3} \quad (10)$$

$$TH_{ij}^{DIOcount}(T_i) = \frac{T_i}{D1} \times C3 \quad (11)$$

$$Risk_{ij}^{DIOFlooding} = \frac{\max(0, TH_{ij}^{DAO-ACK} - F3)}{TH_{DAO-ACK}} + \frac{\max(0, F4 - TH_{ij}^{DIOcount}(T_i))}{TH_{ij}^{DIOcount}(T_i)} \quad (12)$$

3.3.3.2 DAO flooding attack Where $TH_{ij}^{DAOcount}(T_i)$ is threshold of DAO received count from node j in the period T_i . $TH_{ij}^{DAOcount}(T_i)$ can be determined by the value of C3 (ETX_{ij}) and F7 ($NS_{ij}^{DIO}(T_i)$) shown as Eq. (13). Equation (14) calculates the risk of each node conducting DAO Flooding.

$$TH_{ij}^{DAOcount}(T_i) = F7 \times C3 \quad (13)$$

$$Risk_{ij}^{DAOFlooding} = \frac{\max(0, F5 - TH_{ij}^{DAOcount}(T_i))}{TH_{ij}^{DAOcount}(T_i)} \quad (14)$$

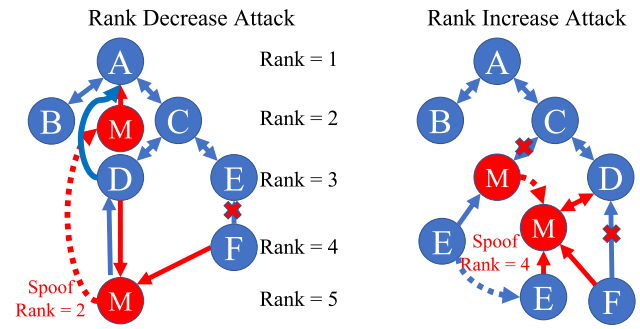


Fig. 9 Rank Decrease Attack and Rank Increase Attack

3.3.3.3 DIS Flooding Attack Figure 8 shows the DIS Flooding Attack. DIS control packets will trigger other normal nodes to send multicast DIO packets and then cause their neighbor nodes to send a DAO response. Thus, this attack will increase the power consumption of the entire IoT Network. Where $TH_{ij}^{DIScount}(T_i)$ is threshold of DAO received count from node j in the period T_i . $TH_{ij}^{DIScount}(T_i)$ can be determined by the value of C3 (ETX_{ij}) and F7 ($NS_{ij}^{DIO}(T_i)$) shown as Eq. (15). Equation (16) calculates the risk of each node conducting DIS Flooding.

$$TH_{ij}^{DIScount}(T_i) = \frac{C3}{F7} \quad (15)$$

$$Risk_{ij}^{DISFlooding} = \frac{\max(0, F6 - TH_{ij}^{DIScount}(T_i))}{TH_{ij}^{DIScount}(T_i)} \quad (16)$$

3.3.4 Rank attack

Figure 9 shows two types of rank attacks: rank decrease attacks and rank increase attacks. The attacker of Rank Decrease Attack will advertise a lower rank value to neighboring nodes so that they will select the attacker as a parent node. It will reduce the performance of the IoT Network because each packet's hop count increases. The attacker of Rank Increase Attack will claim a higher rank value to neighboring nodes so that there will be a loop in the Destination Oriented Directed Acyclic Graph (DODAG). It will destroy the availability and reliability of IoT networks. Thus, it is essential to detect these two types of rank attacks.

The acceptable rank of node j can be determined by the historical rank of the target node j and the rank value of neighbor nodes. The $F9 (\Delta Rank_{i,j}(t = k))$ should not change drastically and $Rank_{i,j}$ should not exist a large gap among the rank value of neighbor nodes. Thus, $Risk_{ij}^{Rankattack}$ can be calculated in Eq. (17) where $TH_{\Delta Rank}$ is threshold of $F9 (\Delta Rank_{i,j}(t = k))$ and $Rank_{i,avgofneighbor}$ is the average value of neighbors' rank and $\sigma_{i,neighborrank}$ is standard deviation of neighbors' rank. $Rank_{i,avgofneighbor}$ and

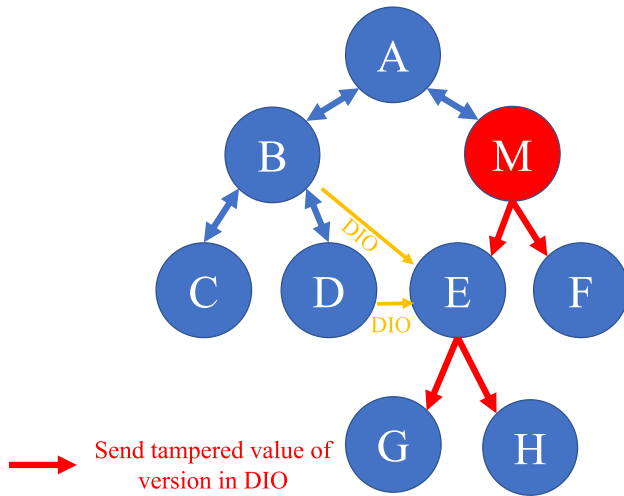


Fig. 10 Version Attack

$\sigma_{i,neighborrang}$ are derived from F8 shown as Eq. (18) and (19). $TH_{\Delta Rank}$ is derived from F9 shown as Eq. (20) which considers the past five values of F9.

$$Risk_{ij}^{Rank Attack} = \frac{F9 - TH_{\Delta Rank}}{TH_{\Delta Rank}} + \frac{\max(0, |F8 - Rank_{i,avgofneighbor}| - 2 * \sigma_{i,neighborrang})}{\sigma_{i,neighborrang}} \quad (17)$$

$$Rank_{i,avgofneighbor} = \frac{\sum_{k=0}^N Rank_{i,k}}{N} \quad (18)$$

$$\sigma_{i,neighborrang} = \sqrt{\frac{1}{N} \sum_{k=0}^N (Rank_{i,k} - Rank_{i,avgofneighbor})^2} \quad (19)$$

$$TH_{\Delta Rank} = \frac{\sum_{k=0}^5 \Delta Rank_{i,j}(t=k)}{5} \quad (20)$$

3.3.5 Version attack

Figure 10 shows the version attack in RPL. The attacker of Version Attack will send the tampered value of the version to neighbor nodes in the DIO packet. The change of version will trigger global repair of topology in RPL. All nodes that receive the new version will trigger the DIO sending procedure and the corresponding DAO and DAO-ACK. It will essentially cause the power consumption to increase in the entire IoT Network. This study uses D2 ($T_{Verupdate}$), F10 ($P_{Ver=NewVerofj}$) and F11 ($t_{ij}^{Verupdate}$). The version update will be ignored when F11 is smaller than D2 to avoid routing updates too frequently. F10 will be calculated only when F11 is larger than D2. $Risk_{ij}^{Versionattack}$ is calculated in Eq. (21).

$$Risk_{ij}^{VersionAttack} = \max(0, 1 - F10) \quad (21)$$

3.3.6 Overall trust calculation

Equation (22) calculates the overall capability. Equation (23) calculates the overall risk.

$$Capability_{ij} = C_1 + C_2 + C_3 \quad (22)$$

$$Risk_{ij} = Risk_{ij}^{BlackholeAttack} + Risk_{ij}^{DIOFlooding} + Risk_{ij}^{DAOFlooding} \quad (23)$$

3.4 Policy decision and enforcement component

After calculating the trust value, the proposed system will make policy decisions for the specific node. Nodes will select the nodes that have the highest trust value to their parents because it will ensure the availability and reliability of the IoT Network. When the trust value of a node is lower than the threshold, the system will regard it as a malicious node and stop interacting with it. That is, this node will be added to the blacklist in other nodes. However, the possibility of misjudgment is taken into account. Therefore, nodes with a higher trust value are banned for a shorter period. On the contrary, if the trust value is lower and the number of times it is found to be risky is higher, the node will be banned for a longer period, as shown in Table 4.

4 Performance analysis

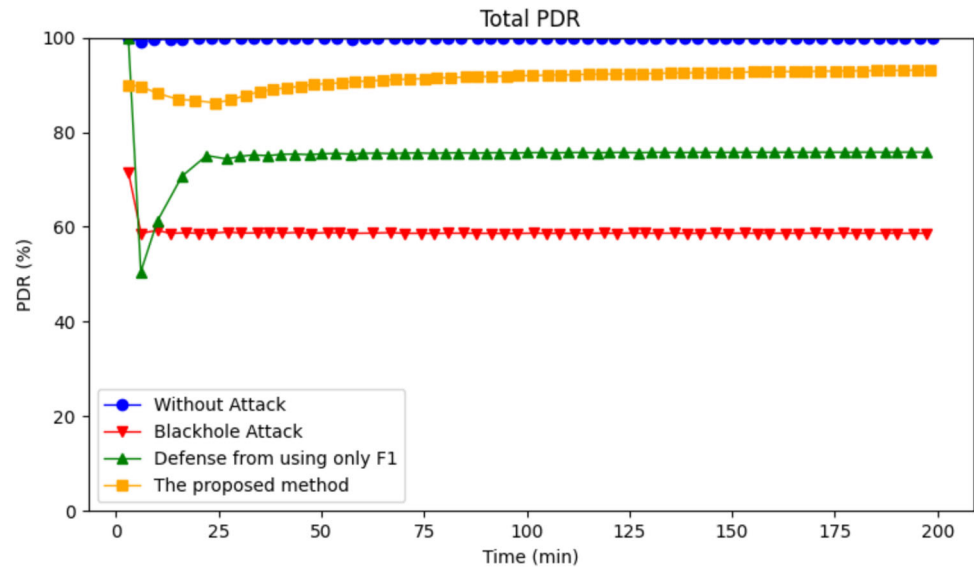
The experimental topology contains 31 nodes, including nine malicious nodes and 22 legitimate nodes, whereas about 30 percent of the nodes are attackers. This study compares the performance with and without the proposed method under various attacks.

4.1 Blackhole attack

Figure 11 shows the Packet Delivery Ratio (PDR) over simulation time under Blackhole Attack. PDR is close to 1 in the scenario without attack, and there is no packet loss. Malicious nodes conducting a Blackhole Attack will drop the forwarding data packet from their children. As a result, PDR is only about 58.6% at the end of the simulation. When each node only uses the Packet Sending Ratio (F1) $PSR_{i,j}(T_i)$ to judge whether their parent nodes are attackers, there will be some misjudgment such that the PDR decreases at the start of time. Furthermore, the more the hop count of a node is, the more likely it will misjudge the parent node because malicious nodes exist in the node's uplink. The proposed method combines features and activities to evaluate the trust of parent and child nodes. Each node can calculate the Packet Forwarding

Table 4 Blacklist time interval according to trust value and number of banned

Severity	Low	Medium	High
Trust value	$TH_2^{Trust} \sim TH_1^{Trust}$	$TH_3^{Trust} \sim TH_2^{Trust}$	$0 \sim TH_3^{Trust}$
Number of banned (N_{Banned})	1 ~ 5	5 ~ 10	> 10
Blacklist time interval	5min * N_{Banned}	1 h * ($N_{Banned} - 5$)	1 day

Fig. 11 Experiment results – Packet Delivery Ratio under Blackhole Attack

Ratio (F2) $PFR_{k,j}(T_i)$ of their child node by using A1, A2 and A3. Therefore, it can detect most attackers.

4.2 DoS attack

Figure 12 shows the degree of impact for different types of DoS attacks, including the DIO, DAO, and DIS Flooding Attacks. DIO Flooding Attack will cause the neighbor nodes of the attacker to send back the DAO message and then trigger a DAO-ACK response. DAO Flooding Attack only triggers the DAO-ACK respectively, so its influence is lower than the other two DoS attacks. DIS Flooding Attack will trigger the multicast DIO and then the DAO and DAO-ACK, respectively. Thus, the influence of the DIS Flooding Attack is higher. Use the control packet overhead to evaluate whether this attack will cause higher power consumption. The proposed method can defend the DoS attack very well.

4.3 Rank attack

In this scenario, the attackers will tamper with the Rank in the DIO packet. The rank decrease attack will cause the neighbor nodes of malicious nodes to choose them as parents and cause inconsistency in rank, decreasing the topology performance. That is, more nodes will select this path for uplink, which will also cause PDR to decline. In Rank Increase Attack, it will cause the rank of nodes far from the root node to be

lower than their neighbor, which can cause the loop in the routing and cause PDR to decrease. Figure 13 shows that the proposed method can essentially reduce the effect of rank attack and cause PDR to rise from 76% to about 89% at the end of the simulation.

4.4 Version attack

In this scenario, the attackers will tamper with the Version Number in the DIO packet. It will trigger the global repair in RPL, which can cause the topology performance to be low. Therefore, it is essential to prevent the wrong version number from propagating. Using the proposed method makes it more possible to reproduce the correct version number. That is, reduce the influence of malicious nodes after some propagating time for the version number. Figure 14 shows that the proposed method can essentially minimize the effect of version attack and cause PDR to rise from 30% to about 82% at the end of the simulation.

5 Conclusions

This study proposes an approach that combines trust evaluation, capabilities, features, and activities to enhance communication efficiency, reliability, and security. The proposed approach considers both the ability of the interaction nodes

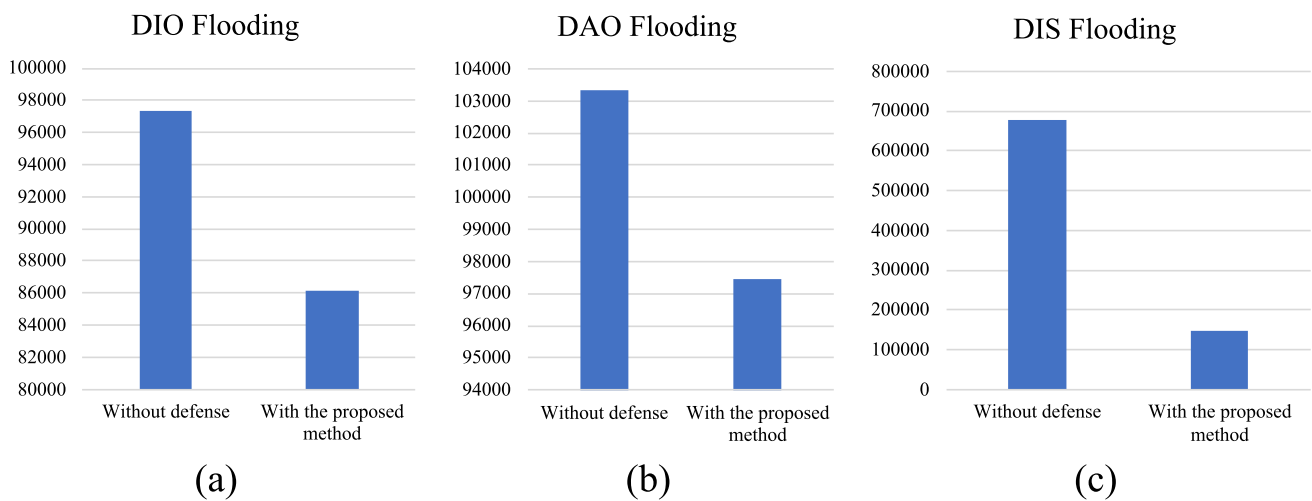
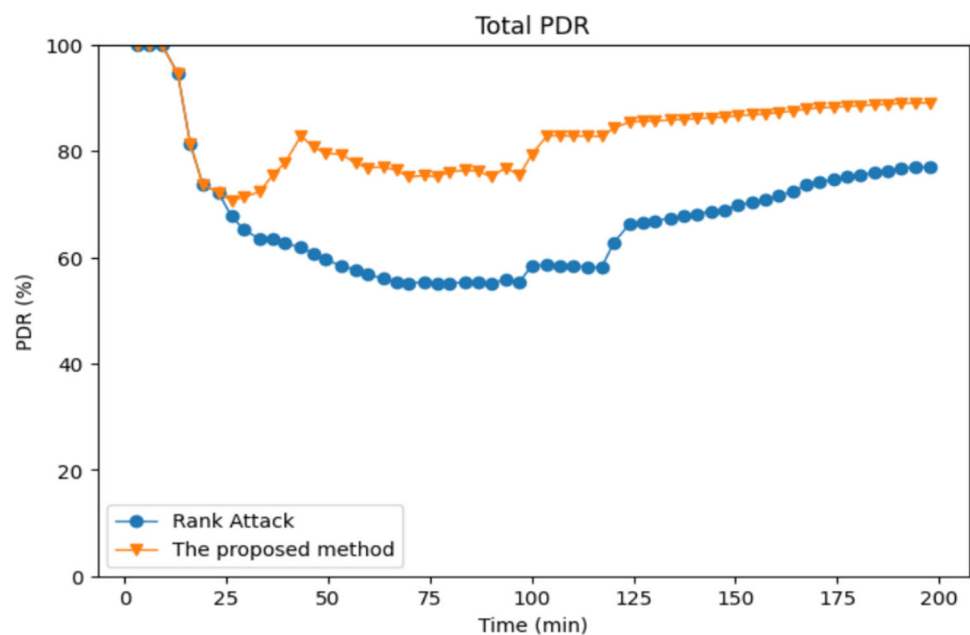


Fig. 12 Experiment results – Control Packet Overhead of DIO (a), DAO (b), and DIS (c) Flooding comparison between without defense and with the proposed method

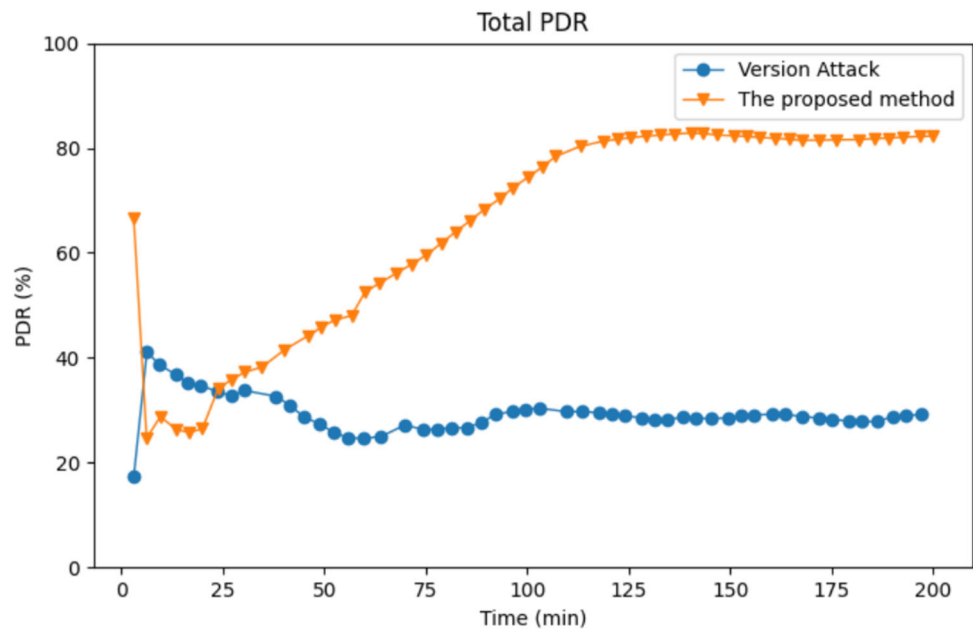
Fig. 13 Experiment results – Rank Attack



and the expected behavior, ensuring accurate node selection and minimizing the risk of misjudgment. By integrating the trust evaluation mechanism, evaluate the reliability and trustworthiness of each node in the network. This enables nodes' past capabilities and behavior when making node selection decisions. It uses the performance capabilities to capture the capabilities of each node to judge whether the node's behavior is acceptable. The features, activities, and data provide

the observed and expected behavior, which can help identify the malicious nodes. Therefore, unlike other methods that may overlook these considerations, the proposed approach provides a robust and trustworthy framework for communication in IoT networks, improving the overall performance and security of the network.

Fig. 14 Experiment results – Version Attack



Acknowledgements This research is supported by the National Science and Technology Council, Taiwan, R.O.C. under Grant no. 112-2221-E-011-091-MY3.

Author contribution All authors wrote the main manuscript text. All authors reviewed the manuscript.

Funding Open access funding provided by National Taiwan University of Science and Technology. National Science and Technology Council, 112-2221-E-011 -091 -MY3, 112-2221-E-011 -091 -MY3

Data availability No datasets were generated or analysed during the current study.

Declarations

Conflict of interest The authors declare no competing interests.

Open Access This article is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International License, which permits any non-commercial use, sharing, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if you modified the licensed material. You do not have permission under this licence to share adapted material derived from this article or parts of it. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by-nc-nd/4.0/>.

References

1. IOT Analytics. State of IoT 2023: Number of connected IoT devices growing 16% to 16.7 billion globally [Online]. Available: <https://iot-analytics.com/number-connected-iot-devices> (2023). Accessed 15 May 2023
2. Research and Markets. Wireless sensor network global market report 2023 [Online]. Available: <https://www.researchandmarkets.com/report/wireless-sensor-network>(2023). Accessed 15 May 2023
3. Kirimat, A., Krejcar, O., Kertesz, A., Tasgetiren, M.F.: Future trends and current state of smart city concepts: a survey. *IEEE Access* **8**, 86448–86467 (2020)
4. Rose, S., Borchert, O., Mitchell, S., Connelly, S. Zero trust architecture. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>(2020). Accessed 16 May 2023
5. MIT Technology Review. 2021 has broken the record for zero-day hacking attacks. [Online]. Available: <https://www.technologyreview.com/2021/09/23/1036140/2021-record-zero-day-hacks-reasons/> (2021). Accessed 16 May 2023
6. Fang, L., Li, Y., Liu, Z., Yin, C., Li, M., Cao, Z.J.: A practical model based on anomaly detection for protecting medical iot control services against external attacks. *IEEE Trans. Industr. Inf.* **17**(6), 4260–4269 (2021)
7. Yun, K., Astillo, P. V., Lee, S., Kim, J., Kim, B., You, I. Behavior-rule specification-based IDS for safety-related embedded devices in smart home. *World Automation Congress (WAC)*, pp. 65–70 (2021)
8. Astillo, P., Jeong, J., Chien, W., Kim, B., Jang, J., You, I.: SMDAps: a specification-based misbehavior detection system for implantable devices in artificial pancreas system. *J. Internet Technol.* **22**(1), 1–11 (2021)
9. Abdelmoumin, G., Rawat, D.B., Rahman, A.: On the performance of machine learning models for anomaly-based intelligent intrusion detection systems for the internet of things. *IEEE Internet Things J.* **9**(6), 4280–4290 (2022)
10. Houda, Z.A.E., Brik, B., Khokhi, L.: “Why should i trust your IDS?”: an explainable deep learning framework for intrusion detection systems in internet of things networks. *IEEE Open J. Commun. Soc.* **3**, 1164–1176 (2022)
11. Abdel-Basset, M., Moustafa, N., Hawash, H., Razzak, I., Sallam, K.M., Elkomy, O.M.: Federated intrusion detection in blockchain-based smart transportation systems. *IEEE Trans. Intell. Transp. Syst.* **23**(3), 2523–2537 (2022)

12. Sadkhan, S.B., Sadkhan, R.S.B. Analysis of different types of digital signature. In: *Proceedings of the International Engineering Conference on Sustainable Technology and Development (IEC)*, pp. 241–246 (2022)
13. Huang, Z., Wang, Q.: A PUF-based unified identity verification framework for secure IoT hardware via device authentication. *World Wide Web* **23**, 1057–1088 (2019)
14. Muzammal, S.M., Murugesan, R.K., Jhanjhi, N.Z., Humayun, M., Ibrahim, A.O., Abdelmaboud, A. A Trust-Based Model for Secure Routing against RPL Attacks in Internet of Things. *Sensors (Basel)*, (2022)
15. Ye, Z., Wen, T., Liu, Z., Song, X., Fu, C.: An efficient dynamic trust evaluation model for wireless sensor networks. *J. Sensors* **2018**, 1–16 (2017)
16. Hashemi, S.Y., Aliche, F.S.: Dynamic and comprehensive trust model for IoT and its integration into RPL. *J. Supercomput.* **75**(7), 3555–3584 (2019)
17. Lahbib, A., Toumi, K., Elleuch, S., Laouiti, A., Martin, S. Link reliable and trust aware RPL routing protocol for Internet of Things. In: *Proceedings of the International Symposium on Network Computing and Applications* (2017)
18. Wadhaj, I., Ghaleb, B., Thomson, C., Al-Dubai, A., Buchanan, W.J.: Mitigation mechanisms against the DAO attack on the routing protocol for low power and lossy networks (RPL). *IEEE Access* **8**, 43665–43675 (2020)
19. Verma, A., Ranga, V. Addressing Flooding Attacks in IPv6-based Low Power and Lossy Networks. In: *Proceedings of the IEEE Region 10 Conference*, pp. 552–557 (2019)
20. Verducci, S., Schröer, A. Social Trust. *International Encyclopedia of Civil Society* (2010)
21. Ross, R., Winstead, M., McEvelley, M. Engineering trustworthy secure systems. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-160v1r1.pdf>. (2022) Accessed 20 May 2023
22. Khan, B.U.I., Goh, K.W., Khan, A.R., Zuhairi, M.F., Chaimanee, M.: Integrating AI and blockchain for enhanced data security in IoT-driven smart cities. *Processes* **12**(9), 1825 (2024)
23. Khan, B.U.I., Goh, K.W., Mir, M.S., Mohd Rosely, N.F.L., Mir, A.A., Chaimanee, M.: Blockchain-enhanced sensor-as-a-service (SEaaS) in IoT: leveraging blockchain for efficient and secure sensing data transactions. *Information* **15**, 212 (2024)
24. Olanrewaju, R.F., Khan, B.U.I., Kiah, M.L.M., Abdullah, N.A., Goh, K.W.: Decentralized blockchain network for resisting side-channel attacks in mobility-based IoT. *Electronics* **11**, 3982 (2022)
25. Khan, B.U.I., Anwar, F., Rahman, F.D.B.A., Olanrewaju, R.F., Goh, K.W., Janin, Z., Rahman, M.A.: SGM: strategic game model for resisting node misbehaviour in IoT-cloud ecosystem. *Information* **13**, 544 (2022)
26. Khan, B., Anwar, F., Rahman, F., Olanrewaju, R., Kiah, M., Rahman, M., Janin, Z.: Exploring manet security aspects: analysis of attacks and node misbehaviour issues. *Malays. J. Comput. Sci.* **35**, 307–338 (2022)
27. Anwar, F., Khan, B.U.I., Kiah, M.L.M., Abdullah, N.A., Goh, K.W. A Comprehensive insight into blockchain technology: past development, present impact and future considerations. *Int. J. Adv. Comput. Sci. Appl.* **13**(11) (2022)
28. Khan, B.U.I., Anwar, F., Olanrewaju, R.F., Kiah, M.L.B.M., Mir, R.N.: Game theory analysis and modeling of sophisticated multi-collusion attack in MANETs. *IEEE Access* **9**, 61778–61792 (2021)
29. Sharmin, A., Olanrewaju, R.F., Khan, B.U.I., Anwar, F., Motakaber, S.M.A., Rosely, N.F.L.M., Hashim, A.H.A. Secure IoT routing through manifold criterion trust evaluation using ant colony optimization. *Int. J. Adv. Comput. Sci. Appl.* **14**(11) (2023)
30. Olanrewaju, R.F., Khan, B.U.I., Morshidi, M.A., Anwar, F., Kiah, M.L.B.M.: A frictionless and secure user authentication in web-based premium applications. *IEEE Access* **9**, 129240–129255 (2021)
31. Olanrewaju, R., Khan, B., Hashim, A., Sidek, K., Khan, Z., Daniyal, H.: The internet of things vision: a comprehensive review of architecture, enabling technologies, adoption challenges, research open issues and contemporary applications. *J. Adv. Res. Appl. Sci. Eng. Technol.* **26**, 51–77 (2022)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.